Despliegue de PowerFit con Tailscale

Programación Web

Javier Carrera

1. Introducción

En esta actividad se desplegó la aplicación PowerFit usando una computadora personal como servidor. El frontend en Angular y la API REST en Spring Boot funcionan fuera del entorno de desarrollo, y se accedió a ellos desde un iPhone mediante la VPN de Tailscale. Además, se publicó un acceso abierto con Tailscale Funnel para entrar sin instalar ninguna aplicación.

2. Arquitectura

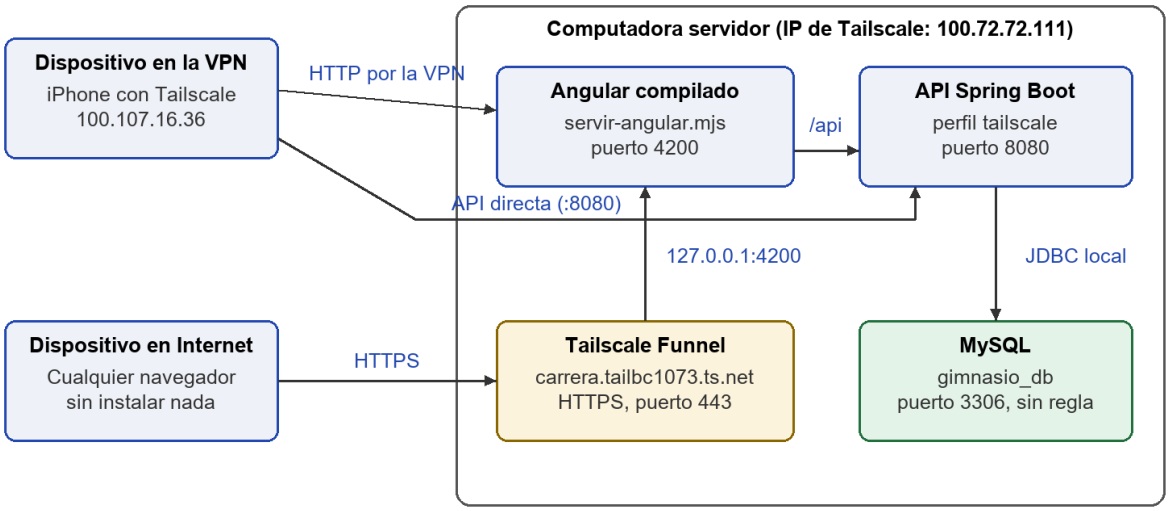


Figura 1. Arquitectura de la solución.

La solución tiene tres capas en la misma computadora. Angular se compiló y se sirve con un pequeño servidor en Node.js. La API de Spring Boot atiende las solicitudes y se conecta a MySQL dentro de la misma máquina.

Tailscale crea una red privada cifrada entre los dispositivos autorizados de una cuenta, sin abrir puertos en el router. Por eso el iPhone llega al servidor aunque esté en otra red. Funnel es una función distinta: publica el frontend en Internet con HTTPS. Las solicitudes a /api que llegan por esa dirección se reenvían a Spring Boot, de modo que la API y MySQL no se publican por separado.

3. Direcciones y puertos

- **Servidor en Tailscale:** 100.72.72.111.
- **iPhone en Tailscale:** 100.107.16.36.
- **Frontend por la VPN:** http://100.72.72.111:4200.
- **API por la VPN:** http://100.72.72.111:8080/api.
- **Acceso público:** https://carrera.tailbc1073.ts.net.
- **MySQL:** puerto 3306, usado por la API dentro del servidor.

4. Configuración

Tailscale. Se instaló en la computadora y en el iPhone, y ambos iniciaron sesión con la misma cuenta. Con tailscale status se comprobó que estaban en la misma red.

Backend. Se agregó el perfil application-tailscale.properties. Hace que la API escuche solo en la IP de Tailscale y acepte únicamente los orígenes del despliegue:

```
server.address=${TAILSCALE_IP}
app.cors.origenes=http://${TAILSCALE_IP}:4200,${TAILSCALE_URL_PUBLICA}
```

Frontend. Se agregó la configuración de compilación tailscale en angular.json, sin cambiar la de desarrollo. Por la VPN, Angular llama a la API con la IP de Tailscale y no con localhost. Por la dirección pública usa /api:

```
apiUrl: window.location.hostname === '100.72.72.111'
  ? 'http://100.72.72.111:8080/api' : '/api'
```

Acceso público. Se aprobó Funnel en la cuenta de Tailscale y se activó con tailscale funnel --bg 4200. Se cierra con tailscale funnel reset.

5. Pasos para ejecutar los servicios

1. Comprobar que el servicio de MySQL y Tailscale estén activos.
2. Crear las reglas del firewall una sola vez, como administrador: despliegue\configurar-firewall.ps1 -CerrarMySQL.
3. Ejecutar despliegue\iniciar-servidor.ps1. El script obtiene la IP de Tailscale, compila Angular y Spring Boot, y abre los dos servicios en ventanas separadas.
4. Abrir la aplicación desde el otro dispositivo.

6. Seguridad y conectividad

El firewall de Windows siguió activo durante todo el proceso. Para el acceso por la VPN se crearon dos reglas que permiten los puertos 4200 y 8080 solo por la interfaz de Tailscale y desde el rango 100.64.0.0/10.

Durante la revisión se encontró que MySQL estaba expuesto: las reglas Port 3306 y Port 33060 permitían conexiones desde cualquier red. Ambas se desactivaron, y la API siguió funcionando porque se conecta dentro del servidor. La comunicación por la VPN va cifrada por Tailscale y el acceso público usa HTTPS.

También se añadió un límite de 10 intentos por minuto para el inicio de sesión y el registro en el servidor del frontend, y la base se limpió, con respaldo previo, para dejar un único administrador. Como la dirección pública queda abierta a cualquier persona, es recomendable cerrarla cuando termine la demostración. La aplicación solo está disponible mientras la computadora permanece encendida.

7. Cambio en el registro de cuentas

Se corrigió el proceso para que el código de verificación ya no pase por el administrador:

1. La persona se registra y recibe un código en su correo.
2. Ella misma lo ingresa en la pantalla “Verificar correo”. Sin este paso no puede entrar ni aparece en las solicitudes.
3. El administrador aprueba o rechaza el registro desde la aplicación, sin ningún código.
4. Si es aprobada, la persona entra con su correo y contraseña.

Para esto se agregó el servicio POST /api/auth/verificar y se eliminó el código de la revisión del administrador.

8. Pruebas y evidencias

Se realizaron estas comprobaciones:

- **Servidor:** la API y el frontend escuchan en las direcciones previstas, y la API responde por la IP de Tailscale (Figura 2).
- **Por la VPN:** el iPhone, conectado a Tailscale, abrió la aplicación con la IP del servidor y mostró los planes obtenidos de la API (Figura 3).
- **Sin la VPN:** con Tailscale apagado y datos móviles, el iPhone abrió la dirección pública (Figura 3).
- **Operaciones a través de la API:** una cuenta real se registró, recibió el código por correo, lo verificó, fue aprobada e inició sesión. El servidor registró estos pasos en menos de un minuto.
- **Reglas del registro:** en una base temporal se comprobó, entre otros casos, que una cuenta sin verificar o sin aprobar no entra, que un código incorrecto se rechaza y que una cuenta rechazada ve el motivo (Figura 4).

Como la base quedó limpia, el resto de operaciones de la aplicación, como registrar clases y pagos, se mostrarán durante la demostración.

```
> tailscale status
100.72.72.111  carrera    carrera-j11@  windows  -
100.107.16.36  iphone-15  carrera-j11@  iOS      offline, last seen 12m ago

> tailscale funnel status
https://carrera.tailbc1073.ts.net (Funnel on)
|-- / proxy http://127.0.0.1:4200

> netstat -ano | findstr LISTENING (puertos 4200, 8080 y 3306)
TCP 0.0.0.0:3306 0.0.0.0:0 LISTENING 7292
TCP 100.72.72.111:4200 0.0.0.0:0 LISTENING 17736
TCP 100.72.72.111:8080 0.0.0.0:0 LISTENING 26972
TCP 127.0.0.1:4200 0.0.0.0:0 LISTENING 17736

> reglas de firewall
Port 3306                   Activa: False
Port 33060                  Activa: False
PowerFit Web (Tailscale)    Activa: True
PowerFit API (Tailscale)    Activa: True

> curl http://100.72.72.111:8080/api/planes (API por la IP de Tailscale)
HTTP 200: [{"id":1,"tipo":"QUINCENAL","nombre":"Plan Quincenal","descripcion":"Acceso libre al gim...
```

Figura 2. Salida de los comandos en el servidor. En esta consulta, el iPhone aparece desconectado porque Tailscale estaba apagado para la prueba pública.

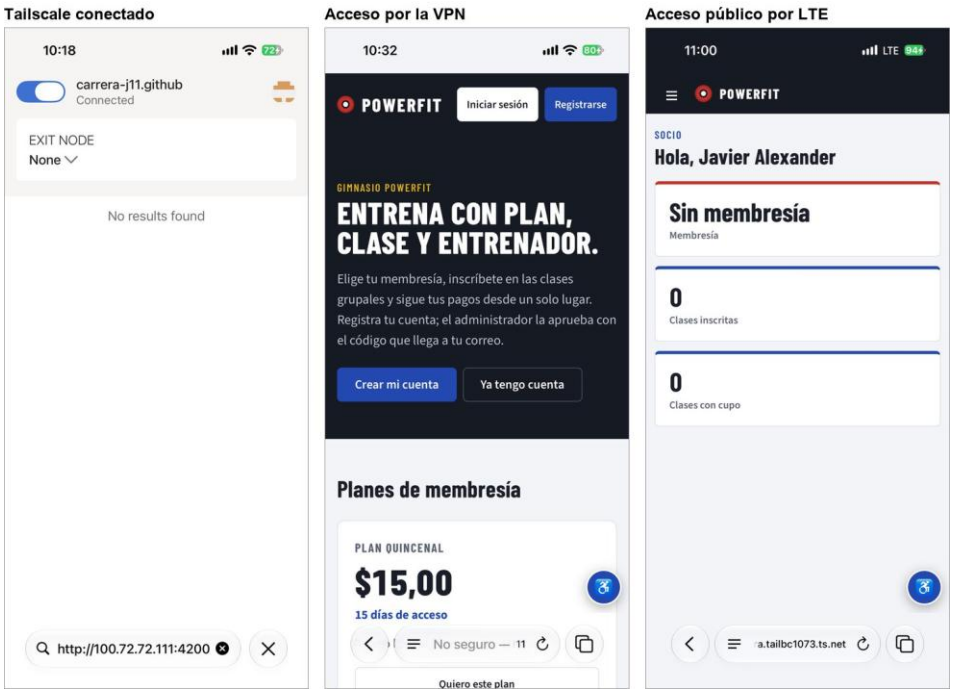


Figura 3. Pruebas de acceso desde el iPhone. La captura por la VPN se tomó antes del cambio en el registro, por lo que aún muestra el texto anterior.

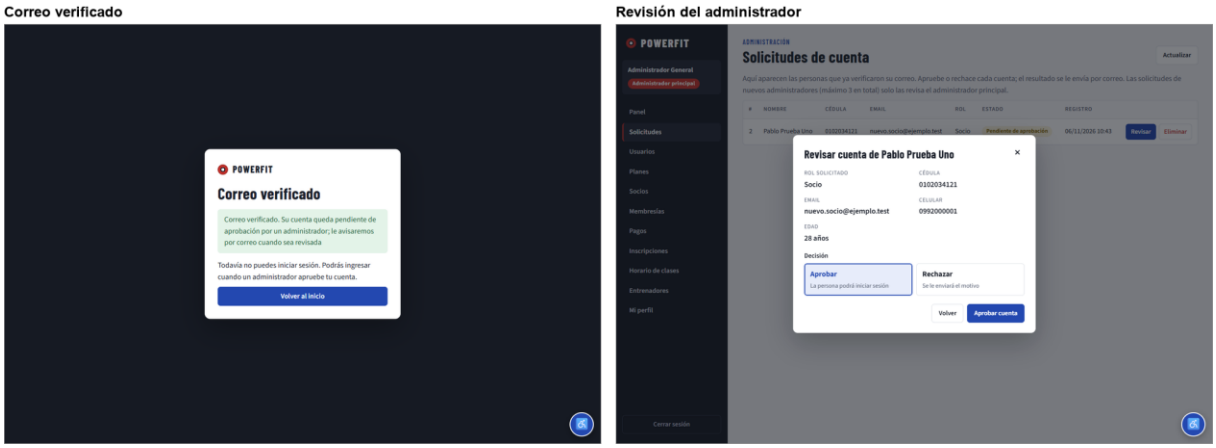


Figura 4. Verificación por la propia persona y revisión del administrador sin código, con datos de prueba.

9. Conclusiones

El despliegue mostró que una aplicación que funciona en localhost necesita ajustes para funcionar desde otro dispositivo: la dirección de la API, los orígenes de CORS, las interfaces en las que escucha cada servicio y el firewall. Tailscale resolvió la conectividad sin abrir puertos en el router, y la revisión de seguridad permitió detectar y cerrar la exposición de la base de datos.